

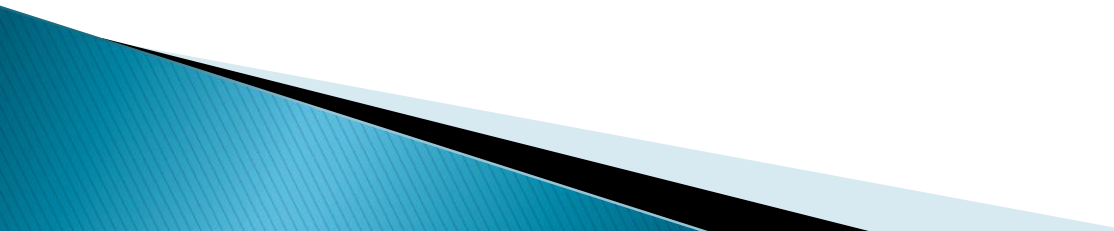
# **CYBER SECURITY PRINCIPLES**

**BY**

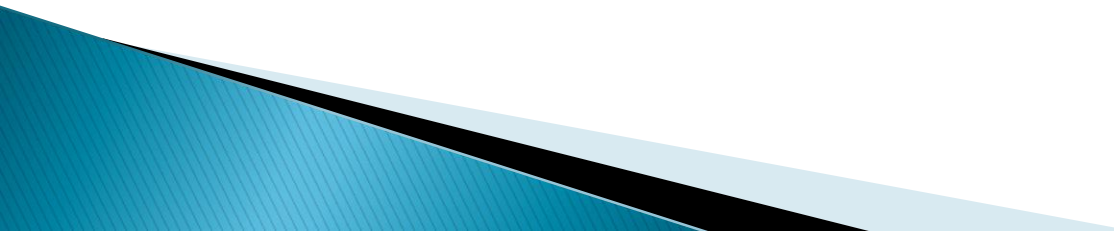
**MERREYLYNE PRAIZE-ANYA**

# **MODULE 2: Policy Goals and Mechanisms**

# OUTLINE

- ▶ Core Cyber security Goals
  - ▶ Risk Management and Governance Frameworks
  - ▶ Incident Response and Crisis Management Policies
  - ▶ Legal, Regulatory, and Compliance Mechanisms
- 

# Core Cyber security Goals

- ▶ The core goals of cyber security are universally defined by the **CIA Triad** (or AIC Triad), a foundational model that guides all security policies, controls, and risk management within an organization.
  - ▶ The three pillars of the CIA Triad represent the fundamental properties that must be protected for any information system.
- 

# Confidentiality

- ▶ Confidentiality is about preventing the disclosure of data to unauthorized parties. It also means trying to keep the identity of authorized parties involved in sharing and holding data private and anonymous. Often confidentiality is compromised by cracking poorly encrypted data

, Man-in-the-middle (MITM) attacks, disclosing sensitive data.

Standard measures to establish confidentiality include:

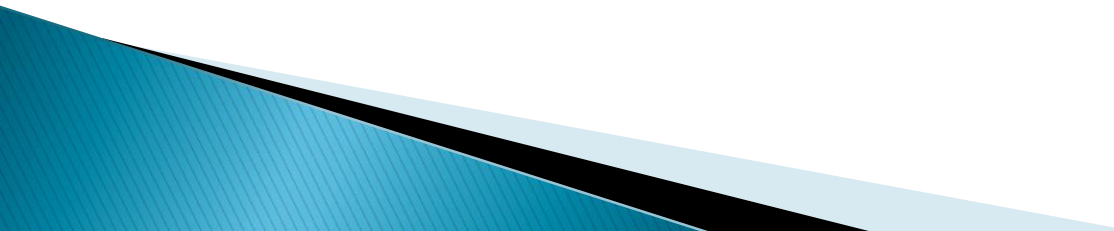
- ▶ ☐ Data encryption
- ▶ ☐ Two-factor authentication
- ▶ ☐ Biometric verification
- ▶ ☐ Security tokens

# Integrity

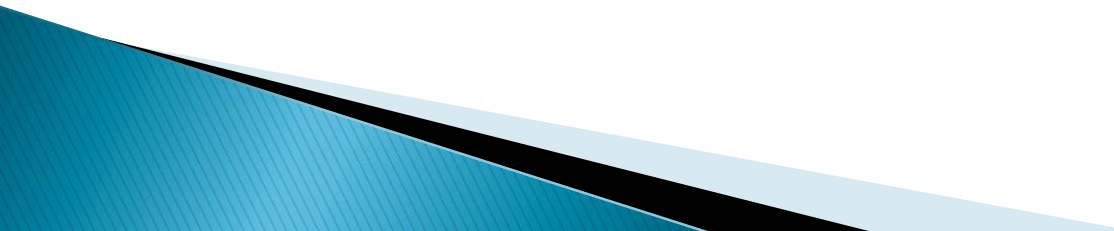
- ▶ Integrity refers to protecting information from being modified by unauthorized parties. Standard measures to guarantee integrity include:
  - ☐ Cryptographic checksums
  - ☐ Using file permissions
  - ☐ Uninterrupted power supplies
  - ☐ Data backups

# Availability

Availability is making sure that authorized parties are able to access the information when needed. Standard measures to guarantee availability include:

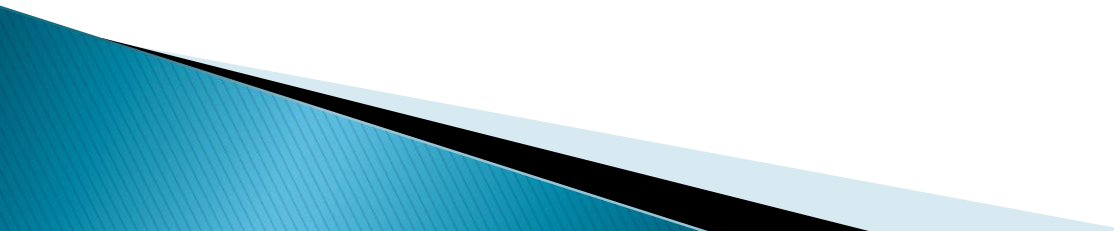
- ▶ Backing up data to external drives
  - ▶ Implementing firewalls
  - ▶ Having backup power supplies
  - ▶ Data redundancy
- 

# Risk Management and Governance Frameworks

- ▶ Cyber security governance is the practice of defining and implementing policies, frameworks, and controls. It ensures the security and resilience of your organization's information systems and data, aligning with broader IT governance principles.
  - ▶ **Cyber security Governance** is the framework that provides leadership, structure, and oversight to ensure an organization's security strategy aligns with its overall business strategy.
- 



# Risk Management and Governance Frameworks

- ▶ It ensures compliance with industry-specific regulations, standards, and best practices, such as those set forth by entities like the National Cyber Security Centre (NCSC) and the Chartered Institute of Information Security (CIIISec).
  - ▶ Through regular assessments, audits, and continuous improvement efforts, your organization can strengthen their cyber resilience and enhance their overall security posture.
- 

# What are the risks of not having proper cyber security governance?

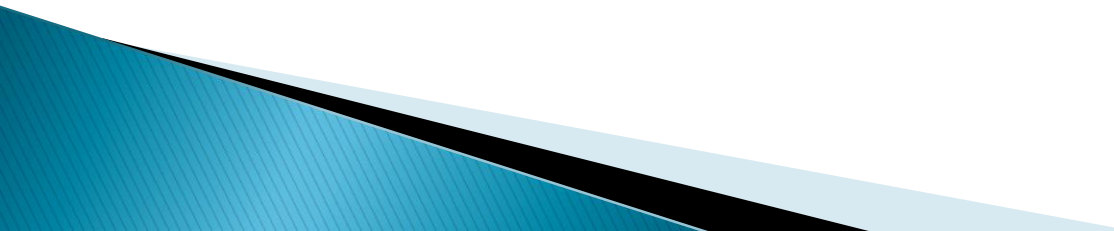
- ▶ Without proper cyber security governance, your organization risks exposing itself to cyber breaches and incidents, which can lead to significant financial and reputational damage.

# Common Cybersecurity Governance Frameworks

## a) **NIST Cybersecurity Framework (NIST-CSF)**

A voluntary framework focusing on critical infrastructure.

Five core functions:

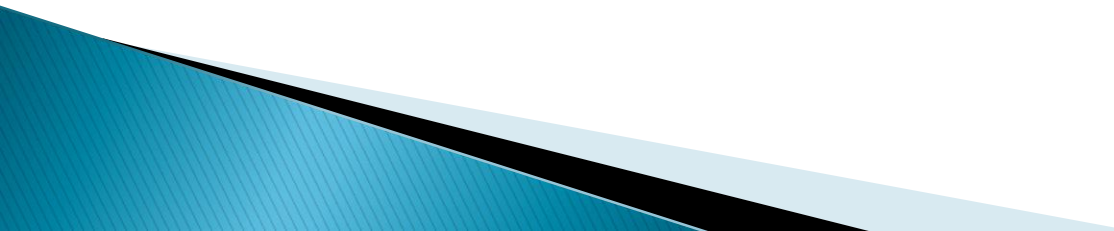
- ▶ Identify
  - ▶ Protect
  - ▶ Detect
  - ▶ Respond
  - ▶ Recover
- 

# Common Cybersecurity Governance Frameworks

## b) ISO/IEC 27001

An international standard for **Information Security Management Systems (ISMS)**.

Requires:

- ▶ Policy creation
  - ▶ Risk assessment
  - ▶ Implementation of controls (Annex A controls)
  - ▶ Continuous improvement (PDCA cycle)
- 

# Common Cybersecurity Governance Frameworks

## ▶ c) COBIT (Control Objectives for Information and Related Technology)

- ▶ Focuses on:
- ▶ Governance of enterprise IT
- ▶ Alignment between IT security and business goals

## d) CIS Controls (Center for Internet Security)

A prioritized list of cyber security best practices including:

- ▶ Asset management
- ▶ Secure configuration
- ▶ Vulnerability management
- ▶ Incident response planning

# key elements of cyber security governance

## A. Risk management

- ▶ Risk Management in cyber security governance involves identifying, assessing, and prioritising risks that could hurt your organisation first.

Or

- ▶ Risk management in cybersecurity involves identifying, analyzing, evaluating, and treating risks that can impact information assets.

# Risk management

## Key Steps in Risk Management

### 1. Risk Identification

- ▶ Identify assets (data, systems, hardware, networks).
- ▶ Identify threats (hackers, malware, insiders, natural disasters).
- ▶ Identify vulnerabilities (weak passwords, unpatched systems).

### 2. Risk Assessment

- ▶ Evaluate **likelihood** of occurrence.
- ▶ Evaluate **impact** on the organization.
- ▶ Prioritize risks using matrix (low, medium, high).

# Risk management

## Key Steps in Risk Management

### 3. Risk Treatment Options

- **Risk Avoidance** – stop the risky activity.
- **Risk Mitigation** – reduce risk through controls.
- **Risk Transfer** – insurance, outsourcing.
- **Risk Acceptance** – accept the risk if low.

### 4. Risk Monitoring & Review

- Continuous monitoring
- Updating risk assessments as threats evolve.



## B. Incident Response (IR)

Incident response is a vital component of cyber security governance. It involves developing and implementing recovery plans to manage and mitigate the impact of cyber security incidents effectively.

It deals with detecting, analyzing, and responding to cybersecurity incidents such as:

- ▶ Malware infections
- ▶ Data breaches
- ▶ Insider threats
- ▶ System outages
- ▶ Ransomware attacks

# Phases of Incident Response (NIST SP 800-61)

## 1. Preparation

- ▶ Establish IR team
- ▶ Create policies
- ▶ Train employees
- ▶ Maintain incident detection tools (SIEM, IDS/IPS)

## 2. Detection & Analysis

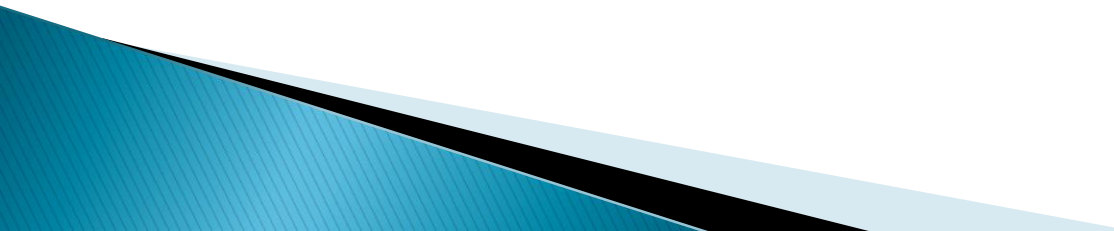
- ▶ Identify indicators of compromise (IOC)
- ▶ Analyze logs
- ▶ Determine severity and classification of the incident

# Phases of Incident Response (NIST SP 800-61)

## 3. Containment

- ▶ Short-term containment (stop immediate spread)
- ▶ Long-term containment (temporary fixes to maintain business continuity)

## 4. Eradication

- ▶ Remove malware, unauthorized users, malicious files
  - ▶ Patch vulnerabilities
  - ▶ Improve defenses
- 

# Phases of Incident Response (NIST SP 800-61)

## 5. Recovery

- ▶ Restore systems from clean backups
- ▶ Monitor systems for signs of weakness
- ▶ Validate service integrity

## 6. Lessons Learned

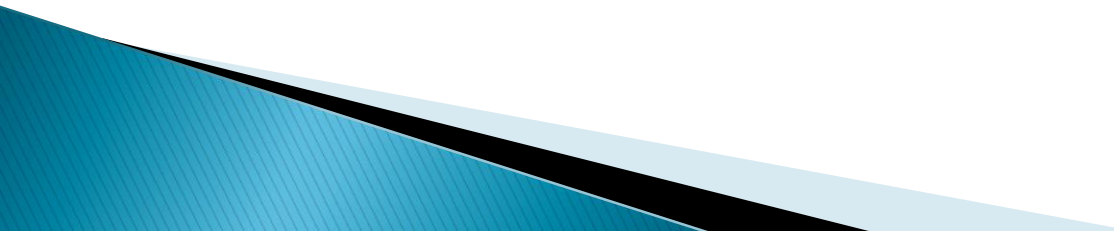
- ▶ Document incident details
- ▶ Identify gaps in policies
- ▶ Update security controls

# Crisis Management

Crisis management is an organization's process and strategy-based approach for identifying and responding to a critical event.

A critical event can be defined as any threat, unanticipated incident, or negative disruption with the potential to impact an organization's people, property, or business processes.

Being prepared to respond to and recover from a critical event requires a sophisticated crisis management plan.

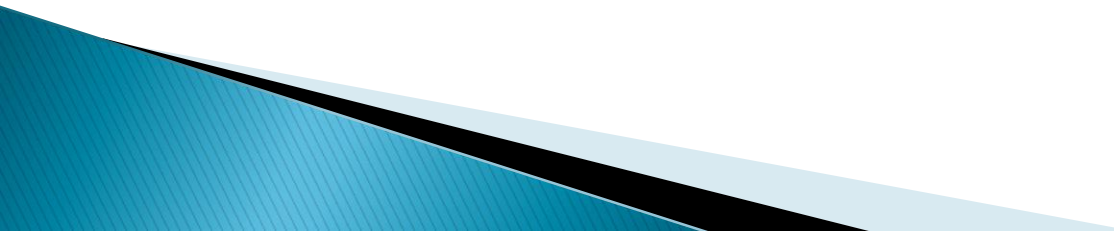


# Crisis Management

Crisis management deals with large-scale incidents that disrupt business operations.

## Key Components

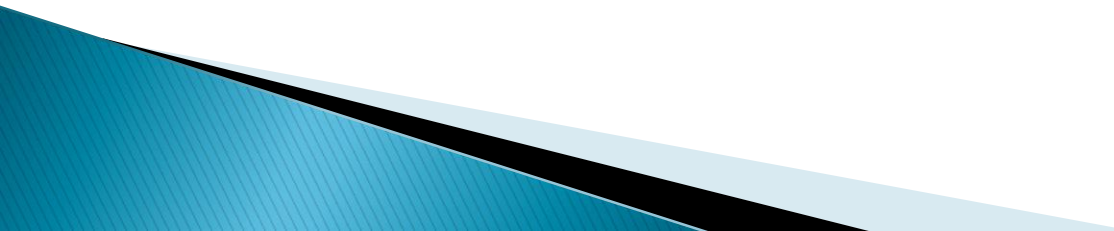
**a. Crisis communication plan:** Is a documented, pre-approved strategy that outlines the procedures, roles, and messages an organization will use to manage and control the flow of information during an unexpected, negative event.



# Crisis Management

## Key Components

**b. Executive decision-making process:** **risk-based approach** used by senior leadership (the C-suite, including the CEO, CFO, and Board) to allocate resources, define the organization's **risk tolerance**, and set the **strategic direction** of the security program. executive decisions translate cybersecurity issues into **business language** (financial impact, reputation, compliance) to ensure alignment with overall organizational goals.



# **Crisis Management**

## **Key Components**

**c. Engagement with regulators, law enforcement, customers**

**d. Business Continuity Planning (BCP)**

Ensures essential services continue during and after a cyber attack.

**e. Disaster Recovery Plan (DRP)**

Focuses on restoring IT systems after major disruptions.



# Legal, Regulatory, and Compliance Mechanisms

- ▶ Organizations are legally obligated to protect specific types of data. Compliance validates that you are following these laws.



What is cybersecurity compliance?

# Cyber Security Compliance

- ▶ Cyber security compliance refers to adhering to and implementing regulations, standards, and practices to safeguard sensitive data and information systems within organizations.
  - ▶ Ensuring cyber security compliance is necessary to protect your organization against cyber threats and data breaches. By aligning with industry-specific regulations such as PCI DSS, organizations can uphold data privacy and build customer trust. Effective compliance management also helps mitigate risk by identifying vulnerabilities and implementing controls to prevent unauthorized access.
- 

# Cyber Security Compliance

- ▶ Maintaining a solid security posture through regular audits and assessments helps your organisation stay resilient against evolving cyber threats. However, non-compliance can lead to financial penalties, reputational damage, and legal consequences.

# Cyber Security Compliance

| Regulation                                                                | Scope/Region           | Focus                                                                                                |
|---------------------------------------------------------------------------|------------------------|------------------------------------------------------------------------------------------------------|
| GDPR( General Data Protection Regulator)                                  | European Union         | Data privacy and "Right to be Forgotten" for individuals. Strict fines (up to 4% of global revenue). |
| HIPAA(Health Insurance Portability & Accountability Act of 1996)          | USA (Healthcare)       | Protection of Personal Health Information (PHI).                                                     |
| PCI-DSS( Payment Card Industry Data security Standard)                    | Global (Finance)       | Security standards for handling credit card information.                                             |
| CCPA/CPRA (California Consumer Privacy Act / California Privacy Right Act | California, USA        | Consumer privacy rights similar to GDPR.                                                             |
| SOX (Sarbanes Oxley Act                                                   | USA (Public Companies) | Corporate financial auditing and data integrity to prevent fraud.                                    |

# Important of cyber security compliance for An organization?

## **1. Protect sensitive data**

## **2. Avoid legal consequences**

When your organization complies with cyber security regulations, you avoid legal consequences such as fines, penalties, and lawsuits resulting from non-compliance with data protection laws and regulations.

## **3. Build trust with customers**

Maintaining cyber security compliance enhances your organization's credibility. It builds customer trust by demonstrating a commitment to data protection, security, and regulatory compliance.